ACC-08 · Service, Application & Non-Human Account Standard

The identities that are not people — which kind to use, who owns them, how their credentials are held and rotated, and how they end.

Field	Value
Document ID	ACC-08
Version	1.0 · Known Good edition, by Kevin Zelman
Catalogue domain	B. Account Usage
Operating tier	Tier 3 — Expert Services creates, holds and reviews every non-human identity. Tier 4 approves any privileged assignment and every multifactor exemption. Tier 1 and Tier 2 act on this document only by refusing an interactive sign-in request and escalating it.
Review cycle	Annually, and on any change to what the tenant can offer as a workload identity.
Relationship to ACC-16	ACC-16 is the intake: how an application arrives at the organization, how its single sign-on is configured and how its claims are mapped. This document is the identity that application carries once it is here. They are the same problem from opposite ends and should be read together; neither repeats the other.

1. Purpose

A familiar scene: two engineers spend a working session on SAML claim configuration for one application integration. That session settles, for one application, a set of questions that arrive with every application: what kind of identity does this thing get, what credential does it carry, who owns it, what may it reach, and what happens when the credential expires. If none of those answers is written down, the next integration settles them all again.

The identities that are not people are the least visible population in the tenant and the least well governed. Nobody sends a leaver notification for a service account. Nobody notices that one has not been used in a year, and nobody notices when one signs in from somewhere it never has before. They hold standing permissions, frequently high ones, and they authenticate with credentials that were set once, by someone who may no longer work here, and written down somewhere that seemed reasonable at the time.

This is not an argument for fewer integrations — modern IT runs on them: the HR system feeding and being fed, the ticketing system, Intune, the identity platform itself, the CRM, and the nightly jobs nobody thinks about until they stop. It is an argument for knowing what they are.

2. The four kinds of non-human identity

These four are routinely all called “service accounts”, which is how the wrong one gets created. They are not variants of one thing; they have different security properties and different failure modes.

Kind	What it actually is	Use when	Assessment
Service account	An ordinary user object in Active Directory or Entra ID, with a password, driven by a script, a scheduled task or an application. Human-shaped: it can sign in interactively, it falls under password policy, and it appears in the directory like a person.	A product can authenticate only as a user, with a username and a password. Where you have them, they rarely go away quickly.	The legacy pattern. Permitted as a documented exception, never as a default. Every control in §6 to §9 applies to it without exception.
Application registration / service principal	An identity in Entra ID belonging to an application rather than a person, holding its own credential — a certificate, or a client secret — and an explicit, enumerable set of consented permissions.	Any new integration against Microsoft 365, Entra ID, or anything speaking OAuth or SAML. The normal case.	The right answer for the great majority of new work. No interactive sign-in, no multifactor question, permissions you can list.
Managed identity	An identity the platform creates for a workload it hosts, whose credential the platform issues and rotates. No credential ever exists for a person to hold, store or leak.	The workload runs on a platform that offers one — in practice, an Azure-hosted resource.	Best available where it applies, and it applies less often than the literature implies in an estate that is largely on-premises and SaaS. Use it whenever it is genuinely on the table.
Shared operational account	One login used by more than one member of IT for an appliance, console or vendor portal that cannot do single sign-on.	The product offers no other way, and that has been confirmed rather than assumed.	Not really a service account — a shared credential with an operational excuse. Governed here so it is at least counted. The goal is fewer of them each year.

3. Which one to use — and the default for anything new

> **A new integration gets a workload identity. It does not get a person-shaped account with a password.**
>
> The default is an Entra application registration with a CERTIFICATE credential, or a managed identity where the platform hosting the workload offers one. That is the answer unless a documented exception says otherwise.
>
> This is not a matter of taste. A user account with a password can sign in interactively, so it can be phished, sprayed, and used by whoever finds the password in a runbook. It falls under password policy, so it either expires — taking the integration down — or is exempted, which is worse. And it needs a multifactor exemption, which is a hole cut in the tenant's strongest control.
>
> An application registration has none of those properties: no interactive sign-in, no multifactor question, permissions that are a list somebody can read, and support for two credentials at once — which is what makes rotation possible without an outage.
>
> Where a product genuinely cannot do this — an older on-premises application that authenticates only against Active Directory with a username and a password — a service account is permitted. That is an exception recorded in the register with the reason, not a decision made quietly because it was quicker on the afternoon it was needed.

The exception is recorded in one sentence, naming the product and the technical limitation. "The vendor recommended it" is not the technical limitation; it is a description of the conversation. Ask the vendor whether the product supports OAuth client credentials or a certificate, and record the answer.

4. The owner

Every non-human account has one named staff member accountable for it, and one named deputy. Not a team, not a distribution list, not "IT" — a person, and a second person for when the first is on leave.

> **An account with no owner is an orphan waiting to be exploited.**
>
> Nobody knows what it does, so nobody dares disable it. Nobody knows what it needs, so its permissions are never reduced. Nobody is watching its credential, so the expiry is a surprise. It survives every review because researching it costs more than leaving it alone.
>
> That is precisely why an orphaned service account is one of the most productive things an attacker finds inside a compromised tenant: high standing privilege, no multifactor, a password that has not changed in years, and an institutional reluctance to touch it.
>
> The deputy exists because a single owner on annual leave is exactly how a credential expiry becomes a two-day outage.

The owner	
Asks for it	Raises the request, states in one sentence what the identity is for, and names the systems it must reach.

The owner	
Justifies its permissions	Can explain, at review, why it holds each permission it holds. “It stopped working when we removed that” is an acceptable answer only if it is followed by finding out which permission was actually needed.
Holds the credential	Knows where the secret lives, and has never put it anywhere in §9.
Watches the expiry	Receives the 60, 30 and 7-day notices and raises the rotation ticket. The notice is a prompt, not the plan.
Answers at review	Confirms annually that the integration still exists, still needs what it holds, and still has an owner (§12, ACC-17).
Ends it	Tells Tier 3 when the integration is retired, rather than leaving the account to be found later.
Is replaced when they leave	Ownership transfers before their last working day, and the credential is rotated at separation (§10).

5. The register, and naming

The register is the whole control. Every rule in this document is enforceable only against a list of things that exist. If that list does not exist yet, this is the reason to start it. Appendix A is the field template; the mandatory fields are: what it is, what kind it is, what it is for, who owns it, what it may reach, what credential it carries, when that credential expires, where the secret is stored, whether it is exempt from multifactor and why, and when it was last reviewed.

A field left blank is a defect, not a formatting preference. An account whose purpose is recorded as “integration” has not been recorded.

> **Open question — how many are there?**
> In many shops this document is written against a population that has never been enumerated. That is not a criticism of anybody; it is the normal state of an organization that has been running integrations for longer than it has had a standard for them.
> ACTION: Tier 3 to produce a first enumeration within 60 days of approval — every Entra user object that is not a person, every application registration holding credentials, every service principal with consented permissions, and every on-premises Active Directory account used by a service or a scheduled task. Owner: the Tier 3 lead. Reported to Tier 4.
> The first pass will be incomplete and should be published anyway. A register improves by being wrong in public; it does not improve by being perfect in private, because it never gets finished.

5.1 Naming

- Service accounts carry a distinguishing prefix and name the system and function, not the person who built it — svc-hr-feed, not svc-jsmith. A non-human account named after a member of staff becomes indistinguishable from that member of staff in a log.

- Application registrations carry a display name that names the application and the purpose, and nothing else. “Test app 2” is how a production integration ends up with nobody able to identify it.
- The exact prefixes and forms are settled in ACC-02, not here. That is deliberate: a naming convention extended live while it is still contested is the argument for one document owning naming rather than each standard inventing its own.
- Non-human accounts are hidden from the address book. They are not people and should not autocomplete as though they were.

---

6. Credentials, rotation, and the 3am expiry

6.1 Certificates over secrets

Where an application registration is used, a certificate credential is preferred over a client secret, and it is worth being specific about why. A client secret is a string, and a string can be pasted into a ticket, a chat message or a configuration file — after which there is no way to know where it now is. A certificate’s private key stays in a key store and is referenced rather than copied. The difference is not cryptographic strength; it is that one leaks by accident and the other does not.

6.2 Maximum lifetimes

Credential	Maximum lifetime	Notes
Certificate on an application registration	12 months, 24 by exception	Renewal overlaps: the new certificate is added and confirmed working before the old one is removed.
Client secret on an application registration	6 months, 12 by exception	Only where a certificate is not supported. Record which of those it is.
Service account password	12 months, and on any suspicion	Long, unique, machine-generated. Never a variant of a previous one, and never a word plus a year.
Shared operational account password	90 days, and on every departure of anyone who knew it	This is the operating cost of a shared account. It is also the argument for having fewer of them.
Managed identity	Not applicable	The platform issues and rotates it. Nothing to hold, nothing to expire, nothing to leak. This is the point of them.
Any credential set to “never expires”	Not permitted	Where the platform allows an unlimited credential, an expiry is set anyway. An unlimited credential is an unreviewed one.

6.3 Expiry monitoring — the part that actually matters

> **An expired secret takes an integration down at three in the morning, and the symptom never says so.**
> What appears is “the overnight HR feed did not run”, or “nobody can sign in to the portal”, or a queue quietly filling up that somebody notices on Tuesday. Hours are then spent rediscovering a fact that was knowable months in advance and written on a certificate.
>
> So expiries are TRACKED, not discovered. Every credential expiry date is entered in the register at the moment the credential is issued — not later, not when somebody gets round to it. A credential issued without its expiry recorded is a future outage that has already been scheduled.

1. The expiry date is recorded in the register at issue, by the person who issued it.
2. Tier 3 produces a monthly report of every credential expiring within 90 days, and takes it to Tier 4 as a standing item.
3. The owner and the deputy are notified at 60, 30 and 7 days. Notices go to people, not to a shared mailbox that nobody has been made responsible for reading.
4. Rotate with overlap wherever the platform allows two credentials: add the new one, confirm the integration is using it, then remove the old one. An application registration supports this; a password does not, which is one more reason §3 prefers the former.
5. Record the rotation and the new expiry in the register. A rotation that is not recorded has reset the clock on a date nobody knows.
6. An expiry that arrives with no rotation ticket already open is a defect in this procedure and is reported as one under GOV-01, not treated as bad luck.

---

7. Sign-in, and the multifactor exemptions that hide here

- Interactive sign-in is blocked for every non-human account. If a person can sign in as it, it is not a service account; it is a shared credential.
- Any interactive sign-in attempt against a non-human account is alerted on, not merely logged. It is either a misconfiguration or somebody using the credential by hand, and both need to be known about.
- Non-human accounts are not mail-enabled and do not hold a mailbox. Where an integration must send mail, it sends through an authorised path with a defined sender, not from an identity somebody could read.
- A non-human account is never used by a person “just this once”. That sentence is how the credential ends up in a chat message.

> **Be honest about this: service accounts are where multifactor exemptions hide.**
> Every tenant that has deployed multifactor authentication has a Conditional Access exclusion group, and every exclusion group accumulates. The accounts inside it are, by definition, the ones the strongest control does not reach. Because they are not people, they are not swept up in the annual push, nobody complains on their behalf, and they are invisible in every metric that counts users.
>
> External deadlines land hardest here. When a SaaS vendor starts enforcing phishing-resistant multifactor authentication by a set date, integration identities are exactly where that bites, and an exclusion list that cannot be produced before the deadline will be produced after it, under pressure, by an outage.

So the exemptions are not forbidden — that would be a rule the department could not keep. They are made visible and made expensive to hold.

Requirement	What it means	Detail
Enumerated	One named exclusion group, and only one.	Exclusions scattered across several policies cannot be counted, and a control that cannot be counted is not operating. Membership is mirrored in the register.
Justified	One sentence in the register, naming the technical reason.	“Legacy application, authenticates against AD with username and password, vendor confirms no OAuth support, ticket reference.” Not “needed for integration”.
Compensated	Every exempt account carries the controls below.	Source-IP or named-location restriction; interactive sign-in blocked and alerted; certificate credential where possible; permissions scoped to the minimum; a long machine-generated secret held only in the secret store; sign-in activity reviewed.
Reviewed	Every six months by Tier 4, with a presumption of removal.	The question is not “does it still need the exemption?” but “what would it take to remove it?”, with an owner and a date attached to the answer.

8. Permissions, consent, and standing Global Administrator

- Permissions are granted to the specific scope the integration needs and no more. Where the platform supports scoping — an Exchange Online application access policy limiting an application to named mailboxes, for example — it is scoped. An application permission granted tenant-wide reads every mailbox at the organization, and it is granted in one click by somebody who only wanted it to read one.
- Prefer the narrower permission even when it is more work: read where read is enough, one mailbox where one mailbox is enough, one site rather than the tenant.
- Admin consent is granted by Tier 3 only, and every consent is recorded in the register with the date and the person. End-user consent to third-party applications is the mechanism behind illicit consent grant attacks, and it should be restricted at the tenant rather than trusted to judgement (M365-21, M365-22).

- Permissions granted “temporarily” to get something working carry a 90-day expiry and a ticket. Without one, temporary means permanent — this is not cynicism, it is the observed behaviour of every estate.

> **No non-human account holds standing Global Administrator.**
>
> A Global Administrator role on an integration account is a tenant takeover with a service-level agreement attached. It is granted because it is faster than working out which role is actually required, and it is never revisited because the integration works — and a working integration is nobody’s Tuesday morning priority.
>
> It also has no multifactor prompt in front of it, no person to notice the sign-in, and frequently a password in a runbook. It is the strongest credential in the organization held by the least-watched identity.
>
> Where an integration genuinely needs directory write access, it gets the narrowest role that does the job, granted by Tier 4, recorded with the permission list and the reason, and reviewed at six months alongside the ACC-07 privileged review. Where a vendor asks for Global Administrator as a precondition of support, that is a procurement conversation (ACC-11 §8), not a technical one.

---

9. Where a secret must never be

Written as a list because it needs to be quotable, and because every item on it has happened somewhere.

- In a ticket. The ticketing system is not a secret store. Tickets are readable across the desk, exported into reports, and retained for years.
- In a Teams message or a chat, including a chat with yourself. Chat content is retained, searchable, and discoverable (M365-16).
- In a script, a configuration file, or anything under source control. A secret committed once is in the history for ever, and removing the line does not remove it.
- In a shared document, a OneNote, a SharePoint page, a wiki, or a spreadsheet with “passwords” anywhere in its name or its purpose. Also: a whiteboard, a sticky note, and a printed runbook.
- In an email, including an email to yourself, and including one you intend to delete afterwards.
- In a scheduled task’s stored credential, a mapped drive, or a saved connection, where any alternative exists. Secrets live in the organization’s secret store, are retrieved for use rather than copied out, and are rotated immediately if they have ever been in any of the places above. A secret that has appeared in a ticket is a compromised secret: it is rotated, not redacted. Redaction hides it from the reader; it does not retrieve it from wherever the ticket has already been.

> **Open question — which secret store, and who runs it?**
> If your organization has not formally chosen a store, say so here. Writing the rule without naming the place is how the rule gets ignored, so this is stated rather than glossed.
> ACTION: Tier 3 to recommend a secret storage mechanism to Tier 4 within 60 days of approval — evaluating what is already licensed before buying anything, and covering both application credentials and the shared operational passwords in §2. Owner: the Tier 3 lead.
> Until it is chosen, secrets are held in the existing controlled mechanism and the exposure is recorded as an open risk rather than treated as solved.

10. When the owner leaves

Non-human accounts are not covered by the leaver process, because a leaver notification concerns the person leaving and says nothing about the six integrations they built years ago. The register is what makes them visible at the moment it matters.

1. The HR leaver notification (ACC-01 §5.1) triggers a register query: which non-human accounts does this person own or deputise for?
2. Ownership transfers before the last working day. The deputy becomes the owner, or the leaver's manager names a replacement. This is part of the handover conversation, not an IT afterthought.
3. Every credential the leaver held or could retrieve is rotated at separation. Without exception, and regardless of how the departure went — this is not a statement about the person. It is what makes it possible to say, in a year, that the credential was not available to anybody outside the organization.
4. Shared operational account passwords are changed on the departure of anyone who knew them (§6.2).
5. Where no owner can be found, the account is escalated to Tier 4 with a 30-day disable date. The burden of proof sits on keeping it, not on removing it.
6. Where the leaver is themselves a vendor or contractor, ACC-11 §10 runs as well; the account may be one the organization created for them, and the contract end date may already have passed. ACC-12 sets what happens to the person's own identity. This section is only about the identities they were holding on behalf of the organization, which is a different question and is otherwise nobody's.

11. Decommissioning

This is the hardest part of the document to actually do, because nothing forces it. An integration is retired and the identity behind it simply stays, holding its permissions, until it is found in an audit years later by somebody with no way of establishing what it was for.

Trigger	What happens
The integration is retired	The owner tells Tier 3. This is the clean case and it is the rarest.
A contract ends	ACC-11 §10 offboarding includes any non-human account created for the vendor's integration.

Trigger	What happens
The register review finds no owner	Escalated to Tier 4, disabled after 30 days (§10).
90 days with no sign-in and no explanation	Treated as a decommissioning candidate. Some integrations are genuinely quarterly or annual, which is why the register records the expected cadence — so that silence can be read correctly.
The account is found and nobody can say what it does	Disable it. See below.

11.1 The sequence

1. DISABLE first. Never delete as the first action — deletion removes the evidence of what the account was and, for a service principal, takes its permission grants with it.
2. Observe for 30 days. Watch for the failures that tell you what it was doing.
3. Remove its permissions and group memberships, recording what they were before removal.
4. Revoke and remove its credentials.
5. Delete the object, and record the deletion in the register with the date and the approver. A deleted application registration is recoverable for a limited window; a deleted on-premises account is not, unless it is in a backup somebody can find.
6. Close the register entry rather than deleting the row. The history of what existed is worth more than a tidy list.

> **The rule that unblocks this section**
>
> A non-human account that nobody can explain is decommissioned, not researched indefinitely. If disabling it breaks something, the thing it broke will announce itself within a fortnight and the account can be re-enabled in minutes.
>
> That is a considerably cheaper way of establishing what an account does than an archaeology project, and it is the only approach that ever actually reduces the population. The alternative — leaving it because somebody might need it — is how the organization arrives at an estate nobody can account for.
>
> Do it deliberately: disable in a maintenance window under GOV-04, tell Tier 2 and Tier 3 what has been disabled and why, and be ready to reverse it the same day.

12. Review

- ANNUALLY, the full register goes to Tier 4 under ACC-17: every account, its owner, its purpose, its permissions, its credential state, its last sign-in, and its exemption status.
- EVERY SIX MONTHS, the multifactor exemption list is reviewed against §7, with a presumption of removal.
- MONTHLY, the 90-day credential expiry report (§6.3).

- AT REVIEW the questions are: does the integration still exist; does it still need every permission it holds; is the owner still here and still the right person; when was the credential last rotated; and could this account be moved to a workload identity yet.
- An account whose owner does not respond to the review is escalated, not carried forward with last year's answer.

13. Service levels

Activity	Commitment (per GOV-06)
New non-human identity, complete request	P3 — within 3 coverage days. The design conversation (§3) happens first and may take longer; the creation does not.
Credential rotation, planned	Scheduled before the expiry date, in a maintenance window under GOV-04.
Credential expired and an integration is down	P1 — treated as an outage, with the post-incident question being why §6.3 did not catch it.
Suspected compromise of a non-human credential	P1 — rotate immediately, then investigate under GOV-03. Rotation does not wait for the investigation.
Multifactor exemption request	Tier 4 decision, at the next scheduled review unless the integration is blocked, in which case a recorded interim decision with a 90-day expiry.
Register enumeration and monthly expiry report	On schedule. These are the controls; late is failed.

14. Records

Record	Held in	Retention
Non-human account register, all fields	IT register	Live, plus 3 years after decommissioning
Creation requests and design decisions (§3)	Ticket	3 years
Exception records where a service account was used	IT register + ticket	Life of the account + 3 years
Credential rotations, with dates and new expiries	IT register	3 years
Multifactor exemptions: justification, compensating controls, reviews	Tier 4 record	7 years
Admin consent grants and permission changes	IT register + tenant audit log	7 years
Decommissioning approvals and dates	IT register	Permanent — this is what answers "what happened to it?"

15. Related documents

ID	Title	Relationship
ACC-16	Application Onboarding, SSO & SAML Claims Standard	The intake side of the same problem. ACC-16 brings the application in; this document is the identity it carries.
ACC-07	Privileged & Administrative Account Standard	§8 — no standing Global Administrator, and the six-monthly privileged review.
ACC-11	Vendor, Contractor & Consultant Account Standard	Where the integration belongs to a vendor. §10 offboarding covers the identity too.
ACC-02	Account Naming Standard	Owns naming. §5.1 defers to it.
ACC-01	Account Lifecycle	§5.1 leaver notification is the trigger for §10.
ACC-12	Separation, Retiree & Former-Member Disposition	The person's own identity, as distinct from the ones they owned.
ACC-17	Periodic Access Review & Entitlement Recertification	The annual review in §12.
ACC-03	MFA Enrollment & Account Recovery	§7 — the exclusion group is a hole in that control and is governed here.
M365-21	Tenant Configuration Change Control	Consent settings and Conditional Access changes.
M365-22	Phishing Reporting & Email Threat Response	Illicit consent grants (§8).
M365-16	Retention, Legal Hold & eDiscovery	Why a secret in a chat message is a secret in a discoverable record.
GOV-04	IT Change Management & Maintenance Windows	Rotations and decommissioning run as changes.
GOV-03	Security Incident Response	Suspected credential compromise.
GOV-01	SOP Catalog Governance	§6.3 defect reporting.

Appendix A — The register: mandatory fields

One row per non-human identity. A blank in any field below is a defect, not a formatting preference.

Field	What goes in it
Account name / object ID	The exact identifier, so the row can be matched to the directory without guessing.
Kind	Service account / application registration / managed identity / shared operational account (§2).
Purpose	One sentence a colleague could read in three years. Not "integration".

Field	What goes in it
Systems it authenticates to	Named. Both ends of the integration.
Owner and deputy	Two named people. Not a team, and not a distribution list.
Permissions held, and where granted	The list, and the place it was granted — directory role, application permission, group membership, on-premises rights.
Credential type, and expiry date	Certificate / client secret / password / platform-managed, with the expiry entered at issue. This field is what §6.3 runs on.
Rotation interval and last rotation	Both dates.
Where the secret is stored	The store, not the person.
Interactive sign-in blocked?	YES / NO. NO requires a Tier 4 record.
Multifactor exemption?	YES / NO. YES requires the justification, the compensating controls and the review date (§7).
Expected activity cadence	Continuous / daily / weekly / monthly / quarterly / annual. This is how §11 reads silence correctly.
Created — date, ticket, by whom	
Exception recorded?	Where §3 was departed from, the one-sentence technical reason.
Last reviewed — date, by whom	
Decommission trigger	What event should end this account.

Appendix B — New non-human identity checklist

Completed by Tier 3 at creation and attached to the ticket. An unticked line is a gap somebody will inherit.

✓	Step	Evidence
☐	Kind chosen against §2, with a workload identity as the default	Kind recorded
☐	Where a service account was used, the technical exception is recorded in one sentence	Exception text
☐	Named owner AND named deputy confirmed, both aware	Names on ticket
☐	Purpose written in a sentence a stranger could read, and the expected activity cadence recorded	Register entry
☐	Named per ACC-02, not after a person, and hidden from the address book	Account name
☐	Interactive sign-in blocked, and an alert configured for any attempt	Policy reference
☐	Credential type is a certificate, or the reason it is not is recorded	Credential type
☐	Credential expiry date entered in the register at issue	Expiry date

✓	Step	Evidence
☐	Secret placed in the secret store, and nowhere in §9	Store location
☐	Permissions granted at the narrowest scope that works; no Global Administrator	Permission list
☐	Any directory role approved by Tier 4, and any admin consent granted by Tier 3 and recorded	Approval reference
☐	Multifactor exemption: not requested, or justified, compensated and dated	Exemption record
☐	Decommission trigger recorded at creation	Trigger
☐	Register row complete — every field in Appendix A	Register entry

---

Part of the Known Good SOP Catalog by Kevin Zelman, written for small IT shops, contractors and consultants, career-changers and help desk technicians. Adapt the names, tiers and times to your own shop: the times here are cushion, not a promise.